FUTURE INTERNS TASK 1

# Vulnerability Assessment Report

African Freefire Community

africanfreefirecommunity.com

| PREPARED BY | DATE | CLASSIFICATION |
| --- | --- | --- |
| **Idowu Popoola** | **26 March 2026** | **Confidential** |

ASSESSMENT OVERVIEW

# Executive Summary & Methodology

## SUMMARY

This report outlines finding from a non destructive,passive vulnerability assessment conducted on:

**https://africanfreefirecommunity.com**

The goal was to identity potential security misconfiguration that could impact website intercity or user safety.

**Website stable-minor issues found**

## SCOPE

Authorised testing strictly limited to the primary domain only.

africanfreefirecommunity.com

## RULES OF ENGAGEMENT

Testing was 100% passive to ensure zero disruption to availability

## TOOLS UTILIZED

### NMAP

Surface level port enumeration

### OWASP ZAP

Passive Traffic analysis

### Browser DevTools

Headers,cookies & client sides checks

IDENTIFIED VULNERABILITIES

# Findings & Risk Classification

2 MEDIUM | 3 LOW | 5 TOTAL FINDINGS | Detailed analysis provided for MEDIUM risks

| # | FINDING | RISK | IMPACT SUMMARY | STATUS |
|---|---|---|---|---|
| 01 | Content Security Policy (CSP) Header Not Set<br>No browser content rules defined.XSS injection attacks possible | MEDIUM | Malicious scripts in visitors' browsers | NEEDS FIX |
| 02 | Sub Resource Integrity Attribute Missing<br>External files loaded without verification.Tampered scripts could execute | MEDIUM | Malicious third-party scripts could compromise users | NEEDS FIX |
| 03 | Server Leaks Information (via HTTP Responses)<br>Server version/tech stack visible in HTTP headers.Aids reconnaissance | LOW | Attacker gains technology fingerprint | MONITOR |
| 04 | X-Content-Type-Options Header Missing<br>Browser may misinterpret file types. Enables MIME sniffing attacks | LOW | Malicious file content executed in browser | MONITOR |
| 05 | Strict-Transport-Security (HSTS) Header Not Set<br>HTTPS not strictly enforced.Downgrade to HTTP possible | LOW | Data interception on unsecured connections | MONITOR |

Medium — Fix within 30 days

Low — Best practice improvement

FINDING 01 OF 02 — MEDIUM RISK

# Content Security Policy (CSP) Header Not Set

01 | MEDIUM | NEEDS FIX | Low effort to fix

## WHAT IS IT?

A CSP header tells the browser which content sources are trusted.Without it, the browser accepts scripts from ANY source including malicious ones

## BUSINESS IMPACT

Attackers can inject malicious scripts that steal user passwords,session tokens, or redirect players to fake phishing login pages.

## REMEDIATION

Add to your server configuration.

Content-Security-Policy:

default-src ‘self’

Restricts all content to yourown domain only by default

## EVIDENCE - SCREENSHOOT

Response Headers (457 B) Raw

```
Cache-Control: s-maxage=31536000
Connection: keep-alive
Date: Fri, 27 Mar 2026 17:44:12 GMT
ETag: "o0z0gh63fl171z"
Server: nginx/1.18.0 (Ubuntu)
Vary: rsc, next-router-state-tree, next-router-prefetch, next-router-segment-prefetch
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
x-nextjs-cache: HIT
x-nextjs-prerender: 1
x-nextjs-prerender: 1
x-nextjs-stale-time: 300
X-Powered-By: Next.js
```

FINDING 02 OF 02 — MEDIUM RISK

# Sub Resource Integrity Attribute Missing

02 | MEDIUM | NEEDS FIX | Low effort to fix

## WHAT IS IT?

The website loads external files (like JavaScript from a third-party server) but doesn't verify if the file has been secretly altered. Subresource Integrity (SRI) is a feature that checks a file's unique digital fingerprint to ensure it hasn't been modified.

## BUSINESS IMPACT

If a hacker compromises the third-party server hosting those external files, they can swap the safe script with a malicious one. Your website will blindly load it, allowing attackers to steal user data, passwords, or redirect your visitors.

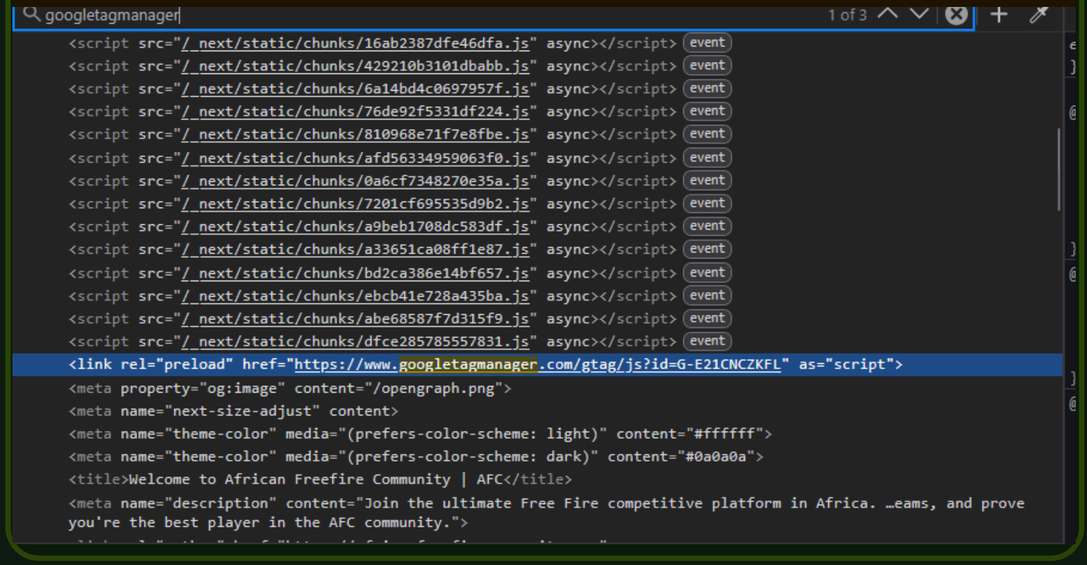
## REMEDIATION

Add an integrity attribute (which contains a cryptographic hash) to the HTML tags that load external scripts.

Example tag:

```
<script src="script.js" integrity="sha384-xyz..."
crossorigin="anonymous"></script>
```

## EVIDENCE - SCREENSHOOT



FINAL SECTION

# Recommendations & Conclusion

## PRIORITY ACTION PLAN

Ordered by urgency

| | | | |
|---|---|---|---|
| 1 | Add Content-Security-Policy header to serve<br>Prevents XSS attacks ,single line config change in server settings | MEDIUM | Within 30 days |
| 2 | Sub Resource Integrity Attribute Missing<br>External files loaded without verification.Tampered scripts could execute | MEDIUM | Within 30 days |
| 3 | Suppress server version info in HTTP response headers<br>Reduces technology fingerprinting, configure server to hide version strings | LOW | Next maintenance cycle |
| 4 | Add X-Content-Type-Options: nosniff header<br>Prevents MIME sniffing, stops browser misinterpreting file content types | LOW | Next maintenance cycle |
| 5 | Enable Strict-Transport-Security (HSTS) header<br>Forces HTTPS at browser level, prevents accidental HTTP downgrade attacks | LOW | Next maintenance cycle |

## CONCLUSION

The African Freefire Community website is operationally stable with no critical vulnerabilities detected. The five findings identified are common misconfigurations that can be resolved with minimal development effort. Addressing the two medium-risk items (CSP and Sub Resource Integrity Attribute Missing) as a priority will significantly improve the security posture of the platform and better protect its 4,000+ active players from web-based attacks

OVERALL SECURITY RATING

**FAIR**